

Contents

Vol 01: Essentials, APT/Kill Chain, Firewalls	2
L01: Course Introduction & Cyber Security Tool Landscape	2
Overview	2
Tool categories	2
Lab setup steps	2
Countermeasures	2
L02: CIA Triad, Risk Assessment & Security Policies	3
Purpose	3
CIA triad	3
Risk assessment steps	3
Policy vs procedure	3
Countermeasures	3
L03: Network Discovery with Nmap & Netcat	3
Nmap — purpose	3
Nmap — usage steps	4
Netcat — purpose	4
Netcat — usage steps	4
Countermeasures	4
L04: Packet Analysis with Wireshark	4
Purpose	4
Usage steps	4
Key display filters	5
Countermeasures	5
L05: APT Lifecycle & Cyber Kill Chain	5
Purpose	5
Cyber Kill Chain (7 stages)	5
MITRE ATT&CK mapping	5
Lab exercise	5
Countermeasures	6
L06: Threat Modeling & Attack Surface Mapping	6
Purpose	6
STRIDE model	6
Attack surface mapping steps	6
Countermeasures	6
L07: Firewall Concepts — Stateful vs Stateless Filtering	7
Purpose	7
Types	7
Rule design principles	7
Countermeasures	7

L08: Linux Packet Filtering with iptables & UFW	7
iptables — purpose	7
iptables — usage steps	7
UFW — simplified frontend	8
Countermeasures	8
L09: Windows Firewall & Host-Based Perimeter Defense	8
Purpose	8
PowerShell usage steps	8
GUI steps	9
Countermeasures	9

Vol 01: Essentials, APT/Kill Chain, Firewalls

Course: nou26_ge86 | **Lectures:** L1–L9

Instructor: Prof. Dr. Nilesh K. Modi | IGNOU/BAOU

L01: Course Introduction & Cyber Security Tool Landscape

Overview

Security tools are software utilities used to **detect**, **prevent**, **analyze**, or **respond to** cyber threats. This course maps tools to the BAOU PGDCS-103 blocks and hands-on lab workflows.

Tool categories

Category	Examples	Role
Reconnaissance	Nmap, theHarvester	Discover assets
Scanning	Nikto, OpenVAS	Find vulnerabilities
Exploitation	sqlmap, Hydra	Demonstrate impact (lab only)
Defense	iptables, Snort, Windows Firewall	Block/detect attacks
Analysis	Wireshark, strings	Inspect traffic/files

Lab setup steps

1. Install VirtualBox or VMware.
2. Download **Kali Linux** ISO from kali.org.
3. Create two VMs on a **host-only network**: Kali (attacker) + Ubuntu/Metasploitable (target).
4. Snapshot VMs before each lab.
5. Verify connectivity: `ping <target-ip>` from Kali.

Countermeasures

- Maintain asset inventory so unknown scanning is detectable.

- Segment lab networks from production LANs.
- Enforce **authorization** before any security testing.
- Log and monitor VM host activity.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L02: CIA Triad, Risk Assessment & Security Policies

Purpose

Establish the security foundation before tool usage. Aligns with PGDCS-101 Block 1 and Nina Godbole's risk-management chapters.

CIA triad

- **Confidentiality** — encryption, access control
- **Integrity** — hashing, change detection
- **Availability** — redundancy, backups, DDoS mitigation

Risk assessment steps

1. Identify assets (data, systems, people).
2. Identify threats and vulnerabilities.
3. Estimate likelihood $\times$ impact $\rightarrow$ risk score.
4. Select controls: avoid, transfer, mitigate, accept.
5. Document in a **risk register**.

Policy vs procedure

- **Policy** — what must be done (e.g., 'All passwords 12 characters').
- **Procedure** — how to do it (e.g., Active Directory GPO steps).

Countermeasures

- Publish acceptable-use and password policies.
- Conduct annual risk assessments.
- Map controls to frameworks (ISO 27001, NIST).

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L03: Network Discovery with Nmap & Netcat

Nmap — purpose

Network mapper for host discovery, port scanning, service/version detection, and OS fingerprinting.

Nmap — usage steps

```
# Host discovery (no port scan)
nmap -sn 192.168.56.0/24

# TCP SYN scan (requires root)
nmap -sS -p- 192.168.56.101

# Service + version detection
nmap -sV -O 192.168.56.101

# Safe script scan
nmap --script safe 192.168.56.101
```

Netcat — purpose

Swiss-army TCP/UDP tool for connectivity testing, banner grabbing, and simple file transfer.

Netcat — usage steps

```
# Listen on port 4444
nc -lvp 4444

# Connect and grab banner
nc -v 192.168.56.101 80

# Port scan (basic)
nc -zv 192.168.56.101 20-80
```

Countermeasures

- Deploy IDS/IPS to detect SYN scans (`nmap -sS`).
- Close unused ports; firewall by default-deny.
- Use port knocking or jump hosts for admin access.
- Rate-limit connection attempts (`fail2ban`).

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L04: Packet Analysis with Wireshark

Purpose

Capture and decode network frames to troubleshoot issues and detect malicious traffic.

Usage steps

1. Select the correct interface (e.g., `eth0`).
2. Apply capture filter: `tcp port 80`.
3. Start capture during a test (browse target web app).

4. Stop capture; apply display filter: `http.request.method == "GET"`.
5. Follow TCP stream to reconstruct sessions.
6. Export objects or save PCAP for evidence.

Key display filters

Filter	Use
<code>ip.addr == 10.0.0.5</code>	Host traffic
<code>tcp.flags.syn == 1</code>	SYN packets
<code>dns</code>	DNS queries
<code>tls.handshake.type == 1</code>	TLS ClientHello

Countermeasures

- Encrypt traffic (TLS 1.2+) to limit passive disclosure.
- Monitor for DNS tunneling and unusual protocols.
- Store PCAPs securely with access controls.
- Use encrypted management channels (SSH, not Telnet).

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L05: APT Lifecycle & Cyber Kill Chain

Purpose

Understand how advanced persistent threats progress through stages — maps offensive tools to defensive detection points.

Cyber Kill Chain (7 stages)

1. **Reconnaissance** — OSINT, Nmap
2. **Weaponization** — malware + exploit paired
3. **Delivery** — phishing email, drive-by
4. **Exploitation** — trigger vulnerability
5. **Installation** — persistence, backdoor
6. **Command & Control** — beacon to C2 server
7. **Actions on Objectives** — data theft, destruction

MITRE ATT&CK mapping

Use [ATT&CK Navigator](#) to map techniques (T1595 Recon, T1190 Exploit Public-Facing App) to tools covered in this course.

Lab exercise

Given a phishing scenario, identify which Kill Chain stages are complete and which Snort/iptables rules would detect each stage.

Countermeasures

- **Defense in depth** — block multiple stages.
- Email filtering + user awareness (break delivery).
- EDR for installation/C2 detection.
- Network segmentation to limit lateral movement.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L06: Threat Modeling & Attack Surface Mapping

Purpose

Systematically identify threats before attackers do; prioritize which tools to deploy for testing.

STRIDE model

Threat	Example	Tool to test
Spoofing	Fake login page	Phishing sim
Tampering	SQL injection	sqlmap
Repudiation	Log deletion	auditd
Info disclosure	Verbose errors	Nikto
DoS	SYN flood	hping3 (lab)
Elevation	SUID exploit	manual

Attack surface mapping steps

1. Draw data-flow diagram (DFD).
2. List entry points: web forms, APIs, Wi-Fi, USB.
3. Assign trust boundaries.
4. Apply STRIDE per component.
5. Rank risks; schedule scans (OpenVAS, ZAP).

Countermeasures

- Reduce attack surface: disable unused services.
- Apply least privilege.
- Re-model after every architecture change.
- Integrate threat modeling into SDLC.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L07: Firewall Concepts — Stateful vs Stateless Filtering

Purpose

Firewalls enforce access control at network boundaries — foundation for iptables (L8) and Windows Firewall (L9).

Types

- **Packet-filtering** — examines headers (IP, port); stateless.
- **Stateful** — tracks connection state; allows return traffic automatically.
- **Application-layer (proxy)** — inspects HTTP/DNS content.
- **Next-gen (NGFW)** — IPS, app awareness, threat intel.

Rule design principles

1. **Default deny** — block all, allow explicitly.
2. **Least privilege** — minimum ports/services.
3. **Document** every rule with owner and expiry.
4. Test rules in staging before production.

Countermeasures

- Place firewalls at trust boundaries (DMZ, internal segments).
- Log denied packets; alert on spikes.
- Combine with IDS (Snort) for deep inspection.
- Review rules quarterly; remove orphans.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L08: Linux Packet Filtering with iptables & UFW

iptables — purpose

Linux kernel netfilter framework for packet filtering, NAT, and mangling.

iptables — usage steps

View current rules

```
sudo iptables -L -v -n
```

Default deny incoming

```
sudo iptables -P INPUT DROP
```

```
sudo iptables -P FORWARD DROP
```

```
sudo iptables -P OUTPUT ACCEPT
```

Allow established connections

```
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

```
# Allow SSH from lab subnet
sudo iptables -A INPUT -p tcp -s 192.168.56.0/24 --dport 22 -j ACCEPT

# Allow HTTP/HTTPS
sudo iptables -A INPUT -p tcp --dport 80,443 -j ACCEPT

# Log then drop everything else
sudo iptables -A INPUT -j LOG --log-prefix "IPTABLES-DROP: "
sudo iptables -A INPUT -j DROP

# Save rules (Debian/Ubuntu)
sudo apt install iptables-persistent
sudo netfilter-persistent save
```

UFW — simplified frontend

```
sudo ufw default deny incoming
sudo ufw allow from 192.168.56.0/24 to any port 22
sudo ufw allow 80,443/tcp
sudo ufw enable
sudo ufw status verbose
```

Countermeasures

- Automate rule deployment (Ansible, Puppet).
- Never expose management ports to the internet.
- Test with `nmap` after rule changes.
- Monitor `/var/log/kern.log` for DROP entries.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L09: Windows Firewall & Host-Based Perimeter Defense

Purpose

Windows Defender Firewall provides host-level inbound/outbound filtering on Windows workstations and servers.

PowerShell usage steps

```
# Check status
Get-NetFirewallProfile | Select Name, Enabled

# Block inbound by default (Domain profile)
Set-NetFirewallProfile -Profile Domain -DefaultInboundAction Block

# Allow RDP from lab subnet only
New-NetFirewallRule -DisplayName "Lab RDP" -`
```

```

-Direction Inbound -Protocol TCP -LocalPort 3389 `
-RemoteAddress 192.168.56.0/24 -Action Allow

# Block outbound SMB to internet
New-NetFirewallRule -DisplayName "Block SMB Out" `
  -Direction Outbound -Protocol TCP -RemotePort 445 `
  -RemoteAddress Internet -Action Block

# List rules
Get-NetFirewallRule | Where-Object {$_.Enabled -eq 'True'}

```

GUI steps

1. wf.msc → Windows Defender Firewall with Advanced Security.
2. Inbound Rules → New Rule → Port/Program/Custom.
3. Assign profile (Domain, Private, Public).
4. Enable logging: Properties → Customize → Log dropped packets.

Countermeasures

- Enforce GPO-managed firewall rules in AD environments.
- Combine with Defender ATP/EDR.
- Disable unnecessary services (SMBv1, Telnet).
- Audit rule changes via Windows Event Log (4946, 4947).

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.